

3. Reglas de negocio

Qué son

Las **reglas de negocio** son restricciones o comportamientos que deben cumplirse para que el sistema represente correctamente el dominio. No son solo “validaciones de formulario”; expresan invariantes del negocio. OWASP además recomienda que los límites y reglas particulares de la aplicación sean reforzados por el modelo de dominio, no dejados al azar en la interfaz.

Reglas que pondría en la V1

Regla 1: Todo dato financiero pertenece a un usuario

Cuentas, categorías, presupuestos y transacciones deben estar vinculados a un usuario propietario.

Por qué:

Porque el sistema es multiusuario y el control de acceso debe basarse en identidad y propiedad del recurso. OWASP insiste justamente en que el acceso debe modelar ownership de registros.

Regla 2: Una cuenta pertenece a un único usuario

No habrá cuentas compartidas en la V1.

Por qué:

Porque simplifica el modelo y reduce ambigüedad en permisos, balances y transferencias.

Regla 3: Una transacción afecta exactamente una cuenta, salvo transferencia

- **income** y **expense** afectan una cuenta
- **transfer** involucra cuenta origen y cuenta destino

Por qué:

Porque una transferencia es un caso especial del dominio y merece una representación explícita.

Regla 4: El monto debe ser positivo

El signo no lo usaría para indicar tipo; usaría:

- `type = income | expense | transfer`
- `amount > 0`

Por qué:

Porque mejora la legibilidad y evita combinaciones absurdas como “expense con amount negativo”. Restricciones como `CHECK` existen justamente para reforzar condiciones de integridad en la base de datos.

Regla 5: El email del usuario es único

No puede haber dos usuarios con el mismo email.

Por qué:

Porque identifica de forma estable al usuario para autenticación y recuperación. PostgreSQL permite reforzarlo con `UNIQUE`.

Regla 6: Una categoría pertenece a un usuario

Las categorías son privadas del usuario en esta V1.

Por qué:

Porque evita complejidad temprana con categorías globales, plantillas compartidas y permisos híbridos.

Regla 7: Una categoría tiene un tipo compatible

Una categoría de gasto solo clasifica gastos; una categoría de ingreso solo clasifica ingresos.

Por qué:

Porque evita ruido analítico y mantiene consistencia semántica.

Regla 8: Un presupuesto se define por usuario, categoría y mes

No debe existir más de un presupuesto para la misma combinación:

`(user, category, month, year)`

Por qué:

Porque el presupuesto debe ser único por período. Eso es un buen candidato para restricción **UNIQUE** compuesta. PostgreSQL soporta unicidad tanto simple como compuesta mediante constraints.

Regla 9: No se puede acceder ni modificar recursos de otro usuario

Aunque el ID exista, si no es del usuario autenticado, la operación se rechaza.

Por qué:

Porque el fallo de control de acceso es de las clases de vulnerabilidad más críticas y OWASP recomienda negar por defecto y modelar ownership.

Regla 10: Las foreign keys son obligatorias donde el dominio lo exige

Ejemplo:

- una transacción debe referenciar cuenta válida
- un presupuesto debe referenciar categoría válida

Por qué:

Porque las foreign keys mejoran calidad e integridad de aplicaciones de base de datos al impedir referencias rotas.